

IDENTITY THREAT DETECTION & RESPONSE

Membedah Serangan Active Directory, Kerberos, dan Kredensial Hibrida di Era Cloud.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Identity Threat Detection and Response (ITDR) & AD Security
Edisi Enterprise (50 Halaman)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Buku ini merupakan panduan pertahanan tingkat lanjut (Advanced Defense) yang menargetkan mekanisme autentikasi dan kontrol akses sentral korporat: Active Directory (On-Premises) dan Entra ID (Cloud).

> **Catatan Forensik:**
> Deteksi yang dibahas dalam dokumen ini sangat bergantung pada pengumpulan Event ID Windows spesifik (seperti 4624, 4768, 4769, 4662, 5136). Tanpa kebijakan Audit Tingkat Lanjut (Advanced Audit Policies) yang dikonfigurasi dengan benar melalui GPO, SIEM Anda akan sepenuhnya buta terhadap serangan-serangan yang dijelaskan di sini.

Filosofi Desain:
Dirancang menggunakan palet *Crimson Red* (melambangkan eksploitasi *Domain Admin* tingkat kritis) dan *Sovereign Gold* (melambangkan tiket Kerberos dan kontrol hak istimewa). Pendekatan Dark Mode dioptimalkan untuk pembacaan log SIEM KQL.

© 2026 Hak cipta dilindungi undang-undang. Panduan Operasional SOC Tier 3.

KATA PENGANTAR

Di medan perang keamanan siber, mengamankan aplikasi dari *malware* adalah hal penting. Namun, ada satu entitas yang jika jatuh ke tangan musuh, maka seluruh jaringan, data, dan masa depan perusahaan Anda akan hancur seketika. Entitas itu adalah **Active Directory (AD)**.

Active Directory adalah Mahkota Kerajaan. Ia memegang kunci setiap server, setiap kotak surat email, dan setiap kebijakan kata sandi di perusahaan. Selama dua dekade, peretas mengetahui fakta ini. Jika sebuah grup *Ransomware* tingkat *Enterprise* (seperti LockBit atau BlackCat) berhasil menyusup ke satu laptop resepsionis, mereka tidak mengenkripsi laptop tersebut. Mereka bergerak senyap, memanen tiket (*Ticket Harvesting*), membajak tiket (*Pass-the-Hash*), dan mengekstrak mahkota tersebut dari Domain Controller Anda dalam proses yang disebut **DCSync**.

Buku ini, *Identity Threat Detection and Response (ITDR), adalah buku panduan Anda untuk menghentikan kejatuhan tersebut. Kita tidak lagi berburu indikator kompromi (IoC) tradisional seperti *Hash MD5* atau alamat IP, karena penyerang di AD menggunakan perangkat bawaan sistem (seperti PowerShell atau WMI) dan kredensial yang sah. Kita akan berburu **Perilaku Identitas**.

Dalam 50 halaman ini, kita akan membedah anatomi Kerberos, cara BloodHound memetakan jaringan Anda, bagaimana serangan *Kerberoasting* dan *Golden Ticket* dieksekusi, serta yang paling krusial: bagaimana menulis aturan *Kibana Query Language (KQL)* yang presisi untuk mencekik serangan tersebut sebelum Domain Controller Anda menyerah.

— Rizki Angga Pratama

Author

DAFTAR ISI (1/2)

BAGIAN I: Jantung Perusahaan (Telemetri AD)

Bab 1.1 Mengapa Active Directory Selalu Ditargetkan? Hlm. 7

Bab 1.2 Kerberos 101: TGT, TGS, dan PAC Hlm. 8

Bab 1.3 Kelemahan Kriptografik Autentikasi NTLM Hlm. 9

Bab 1.4 Windows Event Forwarding (WEF) Hlm. 10

Bab 1.5 Advanced Audit Policies & Event IDs Hlm. 11

Bab 1.6 Sysmon untuk Pemantauan Domain Controller Hlm. 12

BAGIAN II: Reconnaissance & Initial Access

Bab 2.1 Konsep LDAP Enumeration (Recon) Hlm. 14

Bab 2.2 BloodHound & Attack Graphs Hlm. 15

Bab 2.3 KQL: Mendeteksi Aktivitas SharpHound Hlm. 16

Bab 2.4 Password Spraying & Event ID 4625 Hlm. 17

Bab 2.5 Deteksi Smart Spraying (Low & Slow) Hlm. 18

Bab 2.6 LLMNR/NBT-NS Poisoning (Responder) Hlm. 19

Bab 2.7 Eksekusi SMB Relay Attacks Hlm. 20

Bab 2.8 Defensif: Memaksakan SMB Signing (GPO) Hlm. 21

Bab 2.9 Deteksi Anomali Akses Direktori (4662) Hlm. 22

DAFTAR ISI (2/2)

BAGIAN III: Privilege Escalation & Lateral Movement

Bab 3.1 Anatomi Serangan Kerberoasting Hlm. 24

Bab 3.2 KQL: Deteksi Kerberoasting (Event 4769) Hlm. 25

Bab 3.3 AS-REP Roasting (Tanpa Pra-Autentikasi) Hlm. 26

Bab 3.4 KQL: Deteksi AS-REP Roasting (Event 4768) Hlm. 27

Bab 3.5 Pass-the-Hash (PtH) Explained Hlm. 28

Bab 3.6 Mendeteksi PtH di SIEM (Logon Type 9) Hlm. 29

Bab 3.7 Overpass-the-Hash (PtK) Hlm. 30

Bab 3.8 Lateral Movement via PsExec & WMI Hlm. 31

Bab 3.9 KQL: Mendeteksi Layanan Eksekusi Remote Hlm. 32

BAGIAN IV: Domain Dominance & Persistence

Bab 4.1 Ekstraksi Rahasia: DCSync Attacks Hlm. 34

Bab 4.2 KQL: Mendeteksi Replikasi Kredensial Ilegal Hlm. 35

Bab 4.3 Kiamat Kredensial: Golden Tickets Hlm. 36

Bab 4.4 KQL: Anomali Kerberos (TGS tanpa TGT) Hlm. 37

Bab 4.5 Silver Tickets (Service-Level Forgery) Hlm. 38

Bab 4.6 Shadow Credentials (msDS-KeyCredentialLink) Hlm. 39

Bab 4.7 Active Directory Certificate Services (AD CS) Hlm. 40

Bab 4.8 Membangun Model Tiering AD (Tier 0, 1, 2) Hlm. 41

BAGIAN V: Hybrid ITDR & Entra ID (Cloud)

Bab 5.1 Menjembatani On-Prem dan Cloud (Azure AD Connect) Hlm. 43

Bab 5.2 Pass-Through Authentication (PTA) Risks Hlm. 44

Bab 5.3 Primary Refresh Token (PRT) Theft Hlm. 45

Bab 5.4 Identity Containment Playbooks (SOAR) Hlm. 46

Bab 5.5 Isolasi Otomatis Tier 0 Account Hlm. 47

Glosarium ITDR (A-M) Hlm. 48



BAGIAN I

Jantung Perusahaan
& Telemetri Active Directory

BAB 1: FONDASI DIREKTORI

1.1 Mengapa Active Directory Selalu Ditargetkan?

Active Directory (AD) diciptakan oleh Microsoft pada tahun 1999 (Windows 2000) untuk memecahkan satu masalah utama: Administrasi Terpusat. Alih-alih tim TI harus membuat akun pengguna secara manual di 5.000 komputer berbeda, mereka membuat satu akun terpusat di peladen khusus bernama **Domain Controller (DC)**.

Desain sentralisasi ini adalah pisau bermata dua. Ia mempermudah tim TI, sekaligus mempermudah para peretas. Struktur hierarki AD menyimpan segala hal yang dibutuhkan penyerang untuk meruntuhkan perusahaan secara instan:

- **Identity:** Daftar seluruh *Username*, *Password Hash*, dan grup keamanan (seperti *Domain Admins*).
- **Access:** Pengendalian siapa yang boleh masuk (*login*) ke *server* mana, atau mengelola basis data keuangan mana.
- **Policy (GPO):** Group Policy Objects (GPO) memungkinkan pendorongan pengaturan (termasuk pemasangan *malware* atau pencabutan *Antivirus*) secara paksa ke ribuan mesin secara bersamaan.

Bagi pelaku *Ransomware*, mereka tidak perlu bersusah payah menyebar infeksi (*worming*) satu per satu. Mereka cukup meretas *Domain Controller*, lalu menggunakan fitur GPO untuk mendistribusikan berkas enkripsi (*Ransomware payload*) secara otomatis ke seluruh perusahaan dalam hitungan menit.

1.2 Kerberos 101: TGT, TGS, dan PAC

Untuk memahami serangan ITDR, seorang analis harus memahami cara kerja autentikasi **Kerberos** (protokol *default* Active Directory). Kerberos menggunakan sistem "Tiket" berbasis taman hiburan, sehingga pengguna tidak perlu mengirimkan kata sandi aslinya melalui jaringan berulang kali.

Tiga Langkah Utama Kerberos:

1. **AS-REQ / AS-REP (Mendapatkan Tiket Masuk Taman):** Pengguna mengetik *password*. Windows mengenkripsi permintaan (AS-REQ) ke DC menggunakan *hash password* tersebut. DC memvalidasi, lalu memberikan **Ticket Granting Ticket (TGT)**. TGT ini layaknya "Gelang Masuk VIP" di taman hiburan.
2. **TGS-REQ / TGS-REP (Mendapatkan Tiket Wahana):** Pengguna ingin mengakses Peladen *File* (Wahana). Ia menunjukkan TGT-nya ke DC dan meminta akses ke peladen tersebut (TGS-REQ). DC memeriksa apakah pengguna punya hak, lalu memberikan **Ticket Granting Service (TGS)**.
3. **AP-REQ (Naik Wahana):** Pengguna memberikan tiket TGS kepada Peladen *File* secara langsung (DC sudah tidak ikut campur). Peladen *File* mengizinkan akses.

> **Apa itu PAC?**
> Di dalam setiap tiket TGT dan TGS, terdapat **Privilege Attribute Certificate (PAC)**. PAC ini berisi daftar keanggotaan grup pengguna (misal: "Saya anggota tim HR"). Serangan manipulasi tingkat tinggi (seperti *Silver Ticket*) memalsukan isi PAC ini agar peladen mengira penyerang adalah *Domain Admin*.

1.3 Kelemahan Autentikasi NTLM

Meskipun Kerberos adalah protokol utama, Windows mempertahankan protokol warisan (*Legacy*) berumur 30 tahun bernama **NTLM (NT LAN Manager)** demi kompatibilitas aplikasi lama. NTLM adalah kelemahan arsitektural (*Achilles' Heel*) dari sebagian besar jaringan perusahaan.

Berbeda dengan Kerberos yang menggunakan pihak ketiga tepercaya (DC) untuk mengeluarkan tiket, NTLM menggunakan mekanisme *Challenge/Response* secara langsung antara klien dan peladen tujuan.

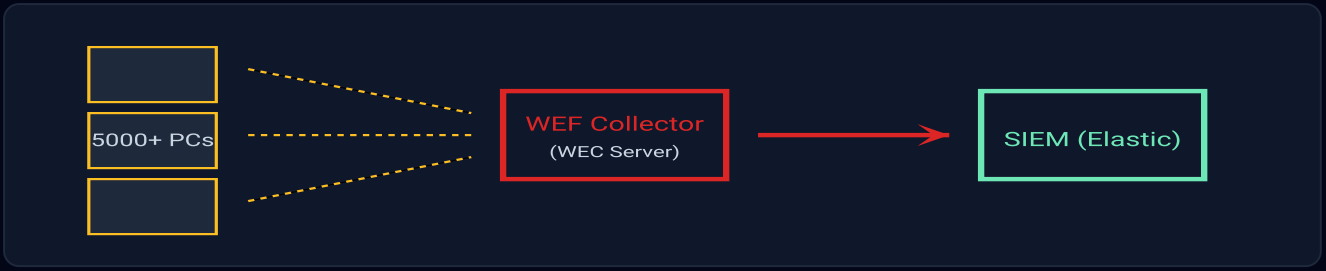
- Klien berkata: "Saya Bob."
- Peladen membalas: "Buktikan. Enkripsikan angka acak (*Challenge*) ini menggunakan *Hash Password* Anda."
- Klien mengirim hasil enkripsinya (*Response*). Peladen meneruskannya ke DC untuk diverifikasi.

Masalah Fatal NTLM: Protokol ini tidak mendukung Validasi Peladen (*Mutual Authentication*). Klien (Bob) tidak memiliki cara untuk memastikan bahwa peladen yang memintanya melakukan enkripsi adalah peladen asli atau peretas. Ini memungkinkan serangan maut bernama **NTLM Relay** atau penyadapan *Hash* menggunakan alat seperti *Responder* (dibahas di Bab 2).

1.4 Windows Event Forwarding (WEF)

Analitik ITDR tidak dapat dilakukan jika sistem SIEM Anda tidak menerima data. Kesalahan terbesar tim keamanan adalah hanya menginstal agen SIEM di *Domain Controller*, padahal serangan *Lateral Movement* justru terjadi antar komputer *Workstation* (*East-West Traffic*).

Untuk menyedot seluruh rekaman log dari 5.000 komputer tanpa memberatkan agen dan lisensi pihak ketiga, *Security Engineer* menggunakan **Windows Event Forwarding (WEF)**, fitur asli tak berbayar dari Microsoft.



Semua PC dikonfigurasi melalui GPO untuk "berlangganan" (*Subscription*) ke WEC Server, dan hanya meneruskan log kritikal (seperti Log *Login* dan Eksekusi Proses). WEC Server ini yang kemudian akan dicekik (*throttled*) dan diteruskan secara massal dan terenkripsi ke mesin SIEM, memotong biaya lisensi (*Ingest Cost*) hingga 80% tanpa kehilangan titik buta.

1.5 Advanced Audit Policies & Event IDs

Windows secara bawaan (*default*) memiliki kebijakan audit yang sangat sunyi (*quiet*). Jika Anda menginstal AD tanpa mengatur *Advanced Audit Policy* via GPO, Anda tidak akan pernah menangkap serangan tingkat lanjut. Pastikan Anda mengaktifkan status "Success & Failure" pada pilar berikut:

EVENT ID	KATEGORI AUDIT	ALASAN KEAMANAN ITDR
4624 / 4625	Logon / Logoff	Jantung visibilitas. Merekam masuk Sukses/Gagal. Penting: Selalu amati nilai **Logon Type** (Tipe 2 = Keyboard Fisik, Tipe 3 = Network/FileShare, Tipe 9 = RunAs/Pass-The-Hash).
4688	Process Creation	Merekam setiap program yang dieksekusi di Windows. **Wajib:** Aktifkan *Include Command Line Data* agar argumen alat *malware* (seperti `powershell.exe -enc`) ikut terekam.
4768 / 4769	Kerberos Auth	Merekam permintaan tiket TGT (4768) dan TGS (4769). Deteksi utama untuk pembajakan Kerberoasting dan AS-REP Roasting.
4662	Directory Service Access	Merekam siapa yang membaca struktur hierarki AD. Deteksi utama untuk penarikan data massal oleh BloodHound dan serangan replikasi sandi (DCSync).

1.6 Sysmon untuk Pemantauan DC

Bahkan *Advanced Audit Policy* Windows masih memiliki celah (seperti tidak dapat mencatat koneksi DNS atau penyuntikan memori jarak jauh/*Remote Thread Injection*). Analis SOC elit menggunakan **System Monitor (Sysmon)** dari *Sysinternals Suite* Microsoft.

Sysmon berjalan sebagai layanan level-sistem (*Device Driver*) dan merekam telemetri tingkat tinggi langsung ke *Event Viewer*. Untuk *Domain Controller*, menginstal agen Sysmon (dengan file konfigurasi yang telah di-*tuning* oleh ahli seperti SwiftOnSecurity atau Olaf Hartong) adalah sebuah keharusan operasional.

> **Event ID Sysmon Kritis untuk AD:**
> - **Event 1 (Process Creation):** Sama dengan 4688, namun Sysmon menyertakan nilai Hash MD5/SHA256 dari aplikasi tersebut langsung di dalam log.
> - **Event 3 (Network Connection):** Merekam IP tujuan setiap aplikasi. Berguna untuk mendeteksi DC yang mencoba terhubung ke IP internet C2 (DC sejati seharusnya tidak *browsing* internet).
> - **Event 10 (Process Access):** Mendeteksi alat eksfiltrasi memori (seperti Mimikatz) yang mencoba membaca kunci kredensial LSASS dari memori RAM.



BAGIAN II

Reconnaissance (Pengintaian)
& Initial Access

BAB 2: RECONNAISSANCE & INITIAL ACCESS

2.1 Konsep LDAP Enumeration (Recon)

Serangan pada Active Directory jarang bersifat seketika. Peretas yang profesional tidak akan langsung menyerang *Domain Controller* (DC) secara membabi buta. Begitu mereka mendapatkan akses ke satu mesin karyawan (melalui Phishing), hal pertama yang mereka lakukan adalah "Menyalakan Lampu" dan membaca Peta (*Reconnaissance*).

Peta tersebut disimpan oleh AD dalam protokol yang disebut **LDAP (Lightweight Directory Access Protocol)**. Secara bawaan (*by design*), Microsoft mengizinkan **setiap pengguna Domain yang sah (Domain User)**, dari resepsionis hingga satpam, untuk melakukan kueri (membaca) daftar seluruh karyawan, daftar peladen, grup siapa anggota *Domain Admin*, dan sesi komputer mana yang sedang menyala.

Bagi peretas, LDAP adalah buku telepon emas. Mereka akan menggunakan alat enumerasi untuk secara senyap menarik struktur ini dan merancang rute terpendek untuk melakukan eskalasi hak (*Privilege Escalation*).

2.2 BloodHound & Attack Graphs

Menarik data LDAP dalam bentuk teks mentah sangat memusingkan. Di tahun 2016, *Red Team* merilis alat revolusioner bernama **BloodHound**. BloodHound menggunakan skrip pengumpul data (bernama **SharpHound**) yang dijalankan pada komputer korban.

SharpHound secara agresif mengkueri AD dan mengumpulkan tiga titik data: Siapa yang *login* di mana (*Sessions*), grup apa mereka tergabung (*Group Memberships*), dan hak administratif lokal apa yang mereka miliki pada mesin lain (*Local Admin Rights*).

Data tersebut diekspor menjadi fail ZIP berformat JSON, dikirim ke komputer peretas, dan diubah menjadi visualisasi **Grafik Berarah (Directed Graph)**.

> **Logika BloodHound: "Six Degrees of Domain Admin"**
> BloodHound akan memberitahu peretas: *"Akun yang baru saja kamu retas (Bob_Magang) bukan Admin. TAPI, Bob_Magang punya hak akses Admin Lokal di Peladen Cetak (Print Server). Di Peladen Cetak itu, ternyata akun Helpdesk_Slamet sedang login (Sesi Aktif). Dan Helpdesk_Slamet tergabung dalam grup Domain Admins!"*
>
> Rute serangan tercipta: Retas Peladen Cetak -> Curi *Password Hash* Slamet dari RAM (Mimikatz) -> Kuasai Domain Controller.

2.3 KQL: Mendeteksi Aktivitas SharpHound

Karena *SharpHound* adalah alat pengintaian *de-facto* (wajib) di awal hampir semua serangan *Ransomware*, mendeteksi alat ini dalam hitungan menit adalah kemenangan mutlak bagi tim SOC. Alat ini sangat bising di sisi *Network* dan membaca ribuan objek dalam detik yang sama.

Kita mendeteksinya di SIEM menggunakan **Event ID 4662 (Directory Service Access)**.

```
/* SIEM KQL: Deteksi BloodHound / SharpHound LDAP Enumeration */ event.code: 4662 AND
winlog.event_data.Properties: ( "*1131f6aa-9c07-11d1-f79f-00c04fc2dcd2*" /* DS-Replication-Get-Changes
*/ OR "*89e95b76-ce4a-45c9-bcbc-6b41559bf66c*" /* Replicating Directory Changes All */ ) /* Agregasi
Threshold: Anomali volume tinggi dalam waktu singkat */ | sequence by user.name with maxspan=1m [any
where event.code == 4662 count > 500]
```

Peringatan *False Positive*: Peladen resmi perusahaan (seperti *Azure AD Connect Server* atau produk *Vulnerability Scanner*) secara sah akan melakukan *query* massal LDAP dan menghasilkan volume *Event* 4662 yang tinggi. *SOC Analyst* wajib melakukan *Whitelisting* pada akun layanan (*Service Accounts*) yang sah tersebut dari kueri KQL ini.

2.4 Password Spraying & Event ID 4625

Setelah pengintaian, jika peretas belum memiliki akses kredensial (misalnya menyerang dari internet ke portal VPN/OWA eksternal), mereka akan mencoba **Brute Force** (Tebak Sandi). Namun, kebijakan perusahaan biasanya mengunci (*lockout*) akun jika salah sandi 5 kali. Brute force tradisional akan segera memicu alarm merah.

Oleh karena itu, penyerang modern menggunakan **Password Spraying** (Penyemprotan Kata Sandi). Metodenya dibalik: Mereka tidak mencoba 1.000 kata sandi pada 1 akun Administrator. Mereka mencoba 1 kata sandi yang sangat umum (misal: `Perusahaan2026!` atau `MusimHujan123`) ke 1.000 akun karyawan yang berbeda secara perlahan.

Setiap akun hanya salah *login* satu kali. Kebijakan *lockout* (Batas 5 kali salah) tidak pernah tercapai, sehingga tidak ada akun yang terkunci. Namun secara ajaib, dari 1.000 akun, biasanya ada 3 atau 4 karyawan malas yang menggunakan sandi tersebut, dan peretas pun berhasil masuk.

2.5 Deteksi Smart Spraying (Low & Slow)

Mendeteksi *Password Spraying* membutuhkan analitik korelasional. Kita mencari lonjakan masif **Event ID 4625 (Logon Failed)** yang berasal dari **satu alamat IP sumber**, namun menargetkan banyak nama akun (`user.name`) yang berbeda-beda.

```
/* SIEM KQL: Deteksi Password Spraying Khusus Active Directory */ event.code: 4625 AND
winlog.event_data.LogonType: ("2" OR "3" OR "10") /* Logika Agregasi Kritis: Hitung akun unik */ | stats
count(distinct user.name) as unique_users_targeted by source.ip | where unique_users_targeted > 20 |
timeframe 15m
```

Kueri di atas memerintahkan SIEM: *"Cari alamat IP manapun yang gagal masuk (*login*) ke lebih dari 20 akun Karyawan yang BERBEDA dalam kurun waktu 15 menit."* Ini adalah tanda tangan absolut dari serangan *Password Spraying* yang digerakkan oleh *bot* (*script*).

2.6 LLMNR/NBT-NS Poisoning (Responder)

Di jaringan LAN kantor, ada kerentanan warisan yang sering digunakan penyerang untuk mencuri kredensial (khususnya *Hash* NTLMv2) tanpa perlu meretas apa pun. Namanya adalah **LLMNR / NBT-NS Poisoning**.

Saat karyawan mengetik nama peladen yang salah eja (salah ketik) di *File Explorer* (misalnya `\\peladen-file-kantorr`, kelebihan huruf 'r'), komputer tidak dapat menemukan alamat IP-nya di DNS Server. Karena putus asa, komputer Windows secara bawaan akan berteriak (*Broadcast*) ke seluruh jaringan LAN: *"Halo semuanya, ada yang tahu di mana letak 'peladen-file-kantorr'?"*

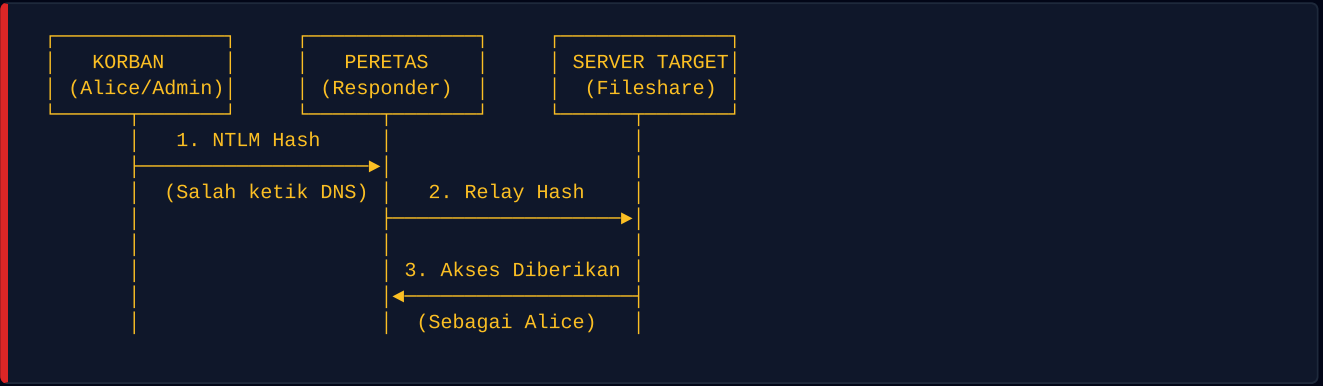
Peretas yang terhubung di jaringan yang sama menyalakan alat bernama **Responder**. Responder bertindak sebagai saksi palsu dan menjawab *Broadcast* tersebut: *"Ya, itu saya! Tolong berikan Hash Autentikasi NTLM kamu untuk bisa masuk."*

Komputer karyawan, tanpa curiga, menyerahkan *Hash NTLMv2* secara otomatis. Peretas menangkap Hash ini dan kemudian memecahkannya (*Crack*) secara luring (*offline*) menggunakan *Hashcat*.

2.7 Eksekusi SMB Relay Attacks

Memecahkan sandi menggunakan *Hashcat* membutuhkan waktu jika sandi korban cukup rumit. Peretas tingkat lanjut menggunakan metode yang jauh lebih mematikan: **SMB Relay**.

Alih-alih memecahkan Hash NTLMv2 yang mereka tangkap dari *Responder*, mereka mengambil sesi autentikasi yang sedang berlangsung (Hash) tersebut dan **memantulkannya (Relay)** ke peladen (target) yang berbeda secara instan.



Jika klien korban (Alice) ternyata memiliki hak Administrator di Peladen Target, peretas dapat merelai kredensial tersebut untuk mengeksekusi komando (*Remote Command Execution*) secara otomatis (menginstal *malware*) tanpa pernah mengetahui kata sandi asli Alice (*Passwordless Hack*).

2.8 Defensif: Memaksakan SMB Signing (GPO)

Deteksi alat *Responder* dan *SMB Relay* di tingkat SIEM sangat sulit karena serangan ini bersifat jaringan (L2/L3) dan menyerupai lalu lintas autentikasi biasa. Oleh karena itu, pendekatan terbaik untuk menangani masalah ini adalah melalui **Pencegahan Arsitektur (Mitigation by Design)**.

> **Cara Membunuh Responder & SMB Relay:**
> 1. **Nonaktifkan LLMNR & NBT-NS:** Buka *Group Policy* (GPO). Pergi ke `Computer Configuration > Administrative Templates > Network > DNS Client > Turn off multicast name resolution` (Set ke *Enabled*). Ini mencegah komputer berteriak ke LAN saat mereka bingung.
> 2. **Wajibkan SMB Signing (SMB Penandatanganan):** GPO: `Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (always).`

Dengan *SMB Signing* diwajibkan (*Require SMB Signing*), setiap sesi komunikasi diverifikasi keabsahannya secara kriptografik dengan klien awal. Jika peretas (berada di tengah) mencoba merelai sesi tersebut, paket tersebut tidak akan memiliki tanda tangan sesi klien asli, dan *Server Target* akan langsung memutus koneksi dengan status *Error*.

2.9 Deteksi Anomali Akses Direktori (4662)

Sebagai rangkuman fase *Reconnaissance*, mata SOC harus selalu terpaku pada **Event ID 4662**. Ini bukan tentang sekadar siapa yang masuk (*login*), melainkan siapa yang *mengakses objek Active Directory secara langsung*.

Penyerang yang terampil sering menggunakan skrip PowerShell berbasis *ActiveDirectory Module* atau *ADSI (Active Directory Service Interfaces)* untuk menarik daftar pengguna (*Users*) atau Grup (*Groups*). Jika pengguna yang mengeksekusi skrip ini adalah `Toni_Marketing`, maka hal ini sangat mencurigakan.

Dalam desain ZTA, akun staf non-TI seharusnya sangat jarang menyentuh LDAP secara bising. Setiap lonjakan Event 4662 yang dilakukan oleh akun karyawan level bawah harus diterjemahkan sebagai indikator yang kuat bahwa mesin mereka (*Endpoint*) telah diretas dan sedang digunakan oleh *threat actor* untuk melakukan penemuan jaringan (*Network Discovery*).



BAGIAN III

Privilege Escalation (Eskalasi)
& Lateral Movement

BAB 3: EKSPLOITASI IDENTITAS

3.1 Anatomi Serangan Kerberoasting

Jika *Password Spraying* gagal, teknik eskalasi hak *offline* (tanpa interaksi mencurigakan langsung dengan korban) yang paling berbahaya adalah **Kerberoasting**. Serangan ini memanfaatkan cara *Active Directory* mengelola *Service Accounts* (Akun Layanan untuk peladen Web/SQL).

Di Kerberos (Bab 1.2), saat Anda ingin mengakses *SQL Server*, DC memberikan Anda **TGS (Ticket Granting Service)**. Yang jarang diketahui adalah: sebagian dari tiket TGS tersebut **dienkripsi menggunakan *Hash Password* milik Akun Layanan (Service Account) SQL Server tersebut.**

Keuntungannya bagi peretas? *Setiap pengguna yang sah (Domain User), siapa pun itu, dapat meminta TGS untuk layanan APAPUN di dalam AD tanpa perlu membuktikan bahwa mereka berhak mengaksesnya.*

Peretas akan menggunakan alat seperti `Rubeus` atau `Invoke-Kerberoast` untuk meminta TGS dari 10 *Service Accounts* yang ada. Mereka tidak menggunakannya untuk masuk. Mereka menyimpannya, mengekspor tiket TGS terenkripsi tersebut ke komputer pribadi mereka di luar jaringan, lalu memecahkan (*crack*) bagian terenkripsi dari TGS tersebut menggunakan *Hashcat/John the Ripper* secara *offline* (yang mana tidak akan memicu alarm kunci akun / *lockout* di SIEM).

3.2 KQL: Deteksi Kerberoasting (Event 4769)

Mendeteksi *Kerberoasting* sangat bergantung pada pembacaan permintaan tiket TGS di Domain Controller, yaitu **Event ID 4769**.

Sinyal kuncinya adalah: algoritma enkripsi RC4 (tipe 0x17). Kebanyakan alat eksploitasi (seperti versi lama dari *Invoke-Kerberoast*) secara eksplisit meminta tiket (*downgrade request*) untuk menggunakan enkripsi RC4 lama karena jauh lebih mudah dipecahkan (*crack*) dibanding standar enkripsi AES-256 modern (tipe 0x12).

```
/* SIEM KQL: Deteksi Kerberoasting (Downgrade Encryption) */ event.code: 4769 AND
winlog.event_data.TicketOptions: "0x40810000" AND winlog.event_data.TicketEncryptionType: "0x17" /* 0x17
adalah RC4 */ /* Saring noise: Jangan ikutkan permintaan untuk akun mesin ($) */ AND NOT
winlog.event_data.ServiceName like "*$" /* Agregasi: 1 akun meminta > 15 layanan berbeda dalam waktu
singkat */ | sequence by user.name with maxspan=5m [stats count(distinct winlog.event_data.ServiceName)
as svc_count] | where svc_count > 15
```

Dengan memaksa (*Enforcing*) seluruh domain untuk menggunakan AES-256 via GPO dan menghapus RC4 (menghasilkan tipe 0x12 atau 0x13), *Kerberoasting* akan menjadi proses *cracking* yang hampir mustahil (butuh waktu puluhan tahun untuk dipecahkan *offline*).

3.3 AS-REP Roasting (Tanpa Pra-Autentikasi)

Jika *Kerberoasting* menargetkan tiket layanan (TGS), ada serangan saudara yang lebih konyol namun sama berbahayanya: **AS-REP Roasting**. Serangan ini menargetkan tahap pertama Kerberos (TGT).

Dalam konfigurasi normal, Kerberos mengharuskan "Pra-Autentikasi" (*Pre-Authentication*). Artinya, Anda harus mengenkripsi stempel waktu (*Timestamp*) dengan *Hash Password* Anda untuk membuktikan Anda tahu kata sandinya, barulah DC memberikan Anda TGT. *(Baca kembali Bab 1.2)*

Masalahnya timbul ketika administrator (karena alasan kompatibilitas aplikasi lama, atau kesalahan teknis) **mematikan centang (Disable)** fitur "Do not require Kerberos preauthentication" pada properti (UAC) akun pengguna tertentu di AD.

Jika ini terjadi, peretas dapat meminta tiket (AS-REQ) **tanpa memberikan kata sandi (tanpa Pre-Auth) sama sekali!** DC akan percaya dan langsung mengembalikan balasan (AS-REP) yang sebagian **dienkripsi dengan Hash Password akun korban**. Peretas tinggal mengambil AS-REP tersebut dan memecahkannya *offline* di komputernya. Mereka tidak pernah membutuhkan sandi awal korban.

3.4 KQL: Deteksi AS-REP Roasting (Event 4768)

Deteksi *AS-REP Roasting* sangat lugas. Kita mencari kejadian **Event ID 4768 (A Kerberos authentication ticket (TGT) was requested)**, dan secara spesifik mencari bendera (*flag*) bahwa Pra-Autentikasi sengaja dilewati atau gagal.

```
/* SIEM KQL: Deteksi AS-REP Roasting Attempts */ event.code: 4768 AND ( /* Pre-Authentication Types
(Tipe 2 = Normal). Jika Kosong atau 0, berarti Pre-Auth dilewati (Bypass) */
winlog.event_data.PreAuthType: "0" OR /* Ticket Options: Flag 0x40810010 menunjukkan RC4 yang diminta
tanpa jaminan pre-auth */ winlog.event_data.TicketOptions: "0x40810010" ) AND
winlog.event_data.TicketEncryptionType: "0x17" /* Enkripsi lemah RC4 */
```

Solusi Deteksi Proaktif (Hunting): Analis SOC proaktif harus menjalankan skrip *PowerShell* (atau *BloodHound*) setiap minggu untuk mencari setiap akun (*User Account*) di AD yang memiliki atribut UAC (`userAccountControl`) dengan status DONT_REQ_PREAUTH aktif. Akun-akun ini harus dimatikan atau dikembalikan konfigurasinya secara paksa ke normal.

3.5 Pass-the-Hash (PtH) Explained

Banyak peretas bahkan tidak repot-repot memecahkan sandi menggunakan *Hashcat*. Mereka menyadari kenyataan arsitektural ini: Windows **tidak** mengirim kata sandi dalam bentuk *plain text* (teks jelas) di jaringan untuk autentikasi (NTLM). Windows mengirimkan **Hash NTLM**.

Jika Windows hanya butuh *Hash* (bukan teks asli), maka peretas juga hanya butuh *Hash*. Inilah esensi dari serangan **Pass-the-Hash (PtH)**.

Saat seorang *Domain Admin* (sebut saja Budi) masuk (*login RDP*) ke laptop karyawan biasa untuk memperbaiki sesuatu, *Hash NTLM* sandi Budi akan membekas (tertinggal sementara) di dalam memori RAM komputer (proses LSASS) tersebut, fitur ini dinamakan (*Single Sign-On Caching*).

Peretas yang meretas laptop karyawan biasa tersebut akan menyuntikkan alat memori seperti **Mimikatz** untuk membaca RAM dan mengekstrak *Hash* milik Budi. Dengan *Hash* tersebut, peretas dapat menyuntikkannya ke sesi mereka (*Inject*) untuk masuk ke peladen *Database* manapun seolah-olah mereka adalah Budi si *Admin*, tanpa pernah mengetahui sandi asli Budi ("KucingHitam123").

3.6 Mendeteksi PtH di SIEM (Logon Type 9)

Mendeteksi injeksi PtH sangat sulit karena terlihat persis seperti koneksi NTLM biasa yang masuk. Namun, kita dapat memanfaatkan parameter **Logon Type (Tipe Masuk)** pada Event ID 4624 (Logon Success).

Kunci dari serangan PtH (dan alat seperti Mimikatz PtH) adalah proses menggunakan API `LogonUser()` dengan flag khusus, yang sering menghasilkan **Logon Type 9 (NewCredentials)**. Tipe 9 biasanya menunjukkan bahwa kredensial lokal pengguna dikloning dan disuntikkan kredensial jaringan baru untuk bertindak (*Impersonate*) sebagai orang lain di jaringan.

```
/* SIEM KQL: Deteksi indikasi kuat Pass-the-Hash (PtH) */ event.code: 4624 AND
winlog.event_data.LogonType: "9" AND winlog.event_data.AuthenticationPackageName: "Negotiate" /*
Pengecualian (Tuning) */ AND NOT winlog.event_data.TargetUserName: ("ANONYMOUS LOGON" OR "*$")
```

Jika *Logon Type 9* terjadi diikuti oleh eksekusi jarak jauh seperti penggunaan WMI atau psexec ke mesin lain (*Lateral Movement*), korelasi tingkat kritis harus dinaikkan.

3.7 Overpass-the-Hash (PtK)

Karena arsitektur ZTA/Modern (seperti penerapan *Kerberos Only*) mulai menonaktifkan protokol NTLM sepenuhnya di seluruh jaringan perusahaan, serangan *Pass-the-Hash (PtH)* klasik perlahan mulai mati.

Namun, peretas tidak kehabisan akal. Mereka menciptakan **Overpass-the-Hash (Pass-the-Key)**.

Cara kerjanya: Peretas mengekstrak Hash NTLM (atau Hash AES) dari memori seperti biasa. Namun bukannya menggunakannya langsung untuk NTLM, mereka memberikannya kembali kepada *Domain Controller* sebagai metode enkripsi pada langkah pertama Kerberos (**AS-REQ**). Karena Hash tersebut benar, DC tertipu, mengizinkannya, lalu memberikan **TGT (Tiket Kerberos Masuk)** murni yang benar-benar baru.

Setelah mendapatkan tiket TGT, peretas melanjutkan serangannya sepenuhnya menggunakan protokol Kerberos (dikenal sebagai **Pass-the-Ticket / PtT**). Ini memungkinkan *Lateral Movement* yang sangat bersih, legal, dan kebal dari blokir NTLM yang diaktifkan perusahaan.

3.8 Lateral Movement via PsExec & WMI

Begitu penyerang mendapatkan kunci rumah (*Ticket/Hash Domain Admin*), mereka harus melompat dari laptop yang mereka retas ke komputer lain (seperti *Domain Controller*). Mereka tidak menggunakan RDP (Remote Desktop) karena terlalu bising secara visual.

Mereka menggunakan alat administratif bawaan sistem operasi (*Living Off the Land / LOLBins*):

- **PsExec (Sysinternals):** Mengirim *malware* ke `ADMIN$` *share* tersembunyi, lalu membuat *Windows Service* palsu jarak jauh untuk mengeksekusinya. Nama layanan biasanya acak (seperti `PSEXESVC.exe`).
- **WMI (Windows Management Instrumentation):** Protokol administratif Microsoft. Menggunakan perintah `wmic node:TargetIP process call create "malware.exe"`. Jauh lebih *stealth* (senyap) dibandingkan PsExec karena tidak menyimpan berkas ke *disk* (*Fileless*).
- **WinRM (PowerShell Remoting):** Membuka *shell* jarak jauh layaknya SSH menggunakan perintah `Enter-PSSession`.

Penggunaan PsExec oleh bukan orang TI harus langsung memicu *Containment SOAR*.

3.9 KQL: Mendeteksi Layanan Eksekusi Remote

Untuk menangkap *Lateral Movement*, kita mengawasi proses induk (*Parent Process*) dari aplikasi yang baru saja terbuka menggunakan **Event ID 4688 (Process Creation)**.

```
/* SIEM KQL: Deteksi PsExec dan WMI Lateral Movement */ event.code: 4688 AND ( /* WMI Remote Execution: Wmiprvse.exe membuat cmd.exe atau powershell.exe */ (winlog.event_data.ParentProcessName: "*\\WmiPrvSE.exe" AND winlog.event_data.NewProcessName: ("*\\cmd.exe" OR "*\\powershell.exe")) OR /* PsExec Execution: service.exe menelurkan psexecsvc.exe (Default) */ (winlog.event_data.ParentProcessName: "*\\services.exe" AND winlog.event_data.NewProcessName: "*\\PSEXESVC.exe") )
```

Anomali Proses WMI:
Proses `WmiPrvSE.exe` secara normal digunakan Windows untuk manajemen latar belakang. Namun, proses ini **TIDAK SEHARUSNYA** meluncurkan jendela baris komando (*command prompt*) `cmd.exe`. Jika WMI meluncurkan `cmd.exe` yang diteruskan dengan parameter eksekusi (seperti menjalankan *malware* atau PowerShell *Base64*), ini adalah eksekusi lateral murni yang berasal dari mesin seberang (di jaringan).



BAGIAN IV

Domain Dominance & Persistence
(Kiamat Kredensial)

BAB 4: DOMAIN DOMINANCE

4.1 Ekstraksi Rahasia: DCSync Attacks

Jika peretas berhasil mengelevasi hak mereka menjadi *Domain Admin*, *Game Over* telah di depan mata. Taktik selanjutnya adalah **Domain Dominance**—memastikan mereka bisa kembali masuk ke jaringan (*Persistence*) kapan saja meskipun Anda telah mengganti seluruh *password* mereka. Langkah pertama adalah pencurian massal via **DCSync**.

Secara arsitektur, sebuah perusahaan biasanya memiliki lebih dari satu *Domain Controller* (DC) untuk redundansi. DC-1 dan DC-2 berkomunikasi menggunakan protokol replikasi DRSUAPI untuk memastikan *password* pengguna selaras (*sync*).

Peretas menggunakan Mimikatz (modul `lsadump::dcsync`) untuk menipu DC. Mimikatz "menyamar" menjadi DC palsu, dan menghubungi DC asli: *"Hai, saya DC-3 yang baru. Tolong sinkronisasikan dan kirimkan semua Password Hash milik seluruh karyawan ke saya sekarang juga, termasuk hash Master KRBTGT."*

Karena peretas menjalankan ini menggunakan kredensial *Domain Admin* yang curian, DC memercayainya dan memberikan mahkota data tersebut tanpa perlawanan.

4.2 KQL: Mendeteksi Replikasi Ilegal

DCSync tidak mengeksekusi *malware* di peladen. DCSync menggunakan protokol Microsoft murni (RPC) atas jaringan, sehingga *Antivirus* dan *Firewall* tidak mendeteksi *byte* berbahaya apa pun. Anda menangkapnya via **Event 4662** di SIEM.

```
/* SIEM KQL: Deteksi DCSync (Illegitimate Replication) */ event.code: 4662 AND
winlog.event_data.Properties: ( "*1131f6aa-9c07-11d1-f79f-00c04fc2dcd2*" /* Hak DS-Replication-Get-
Changes */ AND "*1131f6ad-9c07-11d1-f79f-00c04fc2dcd2*" /* Hak DS-Replication-Get-Changes-All */ ) /*
Filter Kritis: Siapa yang melakukan sinkronisasi? */ /* DC Resmi nama komputernya diakhiri $, contoh:
DC01$ */ AND NOT user.name like "*$"
```

Logika Berburu (Hunting Logic):
Hak untuk melakukan Replikasi Direktori sangatlah sakral. Hanya mesin *Domain Controller* asli (yang nama akunnya berakhiran `$`) dan beberapa agen sinkronisasi (seperti *Azure AD Connect*) yang berhak melakukannya. Jika Anda melihat kueri 4662 (Replikasi) dilakukan oleh akun pengguna manusia (misal: `Admin_Budi` atau `Helpdesk_Tono`), Anda sedang menyaksikan pencurian seluruh basis data *Active Directory* Anda melalui udara.

4.3 Kiamat Kredensial: Golden Tickets

Dari hasil jarahan DCSync, hadiah paling berharga yang diincar peretas adalah satu *Hash Password* spesifik: **Hash akun KRBTGT**.

Ingat Bab 1.2? Saat DC membuat tiket TGT untuk pengguna, tiket itu dienkripsi. **Kunci enkripsi yang digunakan DC untuk menandatangani (memvalidasi) semua tiket tersebut adalah Hash dari akun KRBTGT.**

Begitu peretas memegang Hash KRBTGT ini (dicuri via DCSync), mereka tidak lagi perlu bertanya kepada DC. Peretas dapat menggunakan Mimikatz untuk membuat tiket TGT palsu di laptop pribadi mereka sendiri. Tiket ini dapat berlaku selama 10 tahun (atau berapapun waktu yang mereka ketik), dan tiket ini dapat secara paksa mengklaim: *"Saya adalah CEO Perusahaan, dan saya berada di grup Domain Admins."*

Ini disebut **Golden Ticket (Tiket Emas)**. Saat peretas menyodorkan tiket palsu ini ke DC, DC memverifikasi tanda tangannya (yang dienkripsi dengan KRBTGT). Karena tanda tangannya benar secara matematis, DC akan memercayainya sepenuhnya tanpa bisa membedakan mana tiket asli ciptaannya dan mana tiket palsu ciptaan peretas.

4.4 KQL: Anomali Kerberos (TGS tanpa TGT)

Mendeteksi *Golden Ticket* adalah mimpi buruk forensik karena tiket tersebut secara kriptografik sangat *valid*. Anda tidak bisa mendeteksinya dengan melihat tiketnya sendiri. Anda menangkapnya dengan mencari **celah (anomali) dalam rangkaian kronologis komunikasi.**

Dalam Kerberos normal: Klien selalu meminta TGT terlebih dahulu (Event 4768), BARU klien meminta TGS (Event 4769).

Dalam *Golden Ticket*: Peretas memalsukan (mencetak sendiri) TGT di laptopnya tanpa perlu meminta ke DC (Event 4768 tidak pernah terjadi!). Peretas kemudian melangkah maju dan langsung meminta TGS (Event 4769) menggunakan TGT palsunya tersebut.

```
/* SIEM KQL (Membutuhkan EQL Stateful Engine) */ /* Cari TGS (4769) yang tidak memiliki riwayat TGT (4768) dalam 10 jam terakhir */ sequence by user.name with maxspan=10h [any where event.code == 4768] /* AS-REQ (Normalnya harus ada) */ ! [any where event.code == 4769] /* Namun jika tiba-tiba muncul TGS-REQ tanpa didahului TGT */
```

Indikator lainnya adalah **Ticket Lifetime** (Umur Tiket). AD secara bawaan (*default*) memberikan umur TGT maksimal 10 jam. Saat *Golden Ticket* dibuat di Mimikatz, umur (*lifetime*) *default* yang dicetak secara naif adalah 10 tahun (87.600 jam). Anomali tanggal kedaluwarsa di Event 4769 adalah *red flag* mutlak.

4.5 Silver Tickets (Service-Level Forgery)

Jika *Golden Ticket* mengharuskan kompromi total dari *Domain Controller*, **Silver Ticket (Tiket Perak)** hanya menargetkan satu peladen/layanan spesifik (seperti Peladen *SQL* atau peladen IIS *Web*).

Melalui serangan *Kerberoasting* (Bab 3.1), peretas mendapatkan *Hash Password* dari *Service Account* (Akun Layanan) SQL. Alih-alih menggunakannya untuk masuk secara normal, peretas menggunakan *Hash* tersebut untuk memalsukan (membuat sendiri) tiket **TGS (Ticket Granting Service)**.

Mengapa berbahaya? Ingat, langkah terakhir (AP-REQ) dalam Kerberos adalah pengguna menyerahkan tiket TGS langsung ke Peladen Tujuan. **Domain Controller sudah tidak ikut campur.** Peladen SQL akan memvalidasi tanda tangan TGS (menggunakan *Hash*-nya sendiri), percaya pada *PAC (Privilege Attribute Certificate)* palsu di dalamnya, dan memberikan akses Admin SQL secara total.

Karena DC diabaikan dalam transaksi ini, *Silver Ticket* tidak meninggalkan jejak apa pun (Tidak ada Event 4768 atau 4769) di log *Domain Controller*. Anda HANYA bisa menangkapnya dari Event log 4624 (Logon) **di peladen tujuan secara lokal.** (Inilah alasan mengapa Windows Event Forwarding (WEF) di Bab 1.4 sangat krusial!).

4.6 Shadow Credentials

Metode *Persistence* modern perlahan meninggalkan *Golden Ticket* dan beralih ke penyalahgunaan fitur *Public Key Infrastructure (PKI)* dan *Key Trust* di Active Directory.

Salah satu vektor termutakhir adalah **Shadow Credentials** (menyalahgunakan atribut LDAP `msDS-KeyCredentialLink`). Jika penyerang memiliki kendali administratif awal atas akun *User* atau *Computer* target, alih-alih mereset *password* aslinya (yang akan sangat berisik dan diperhatikan pengguna asli), mereka menambahkan Kunci Publik kriptografi alternatif secara diam-diam ke dalam atribut akun tersebut.

Melalui mekanisme *Kerberos PKINIT*, penyerang sekarang dapat meminta TGT atas nama korban menggunakan Kunci Pribadi (*Private Key*) alternatif mereka sendiri! *Password* asli korban tidak berubah. Autentikasi korban tidak terganggu. Namun, si peretas dapat menyerap akses (TGT) kapan pun mereka mau menggunakan "kredensial bayangan" tersebut.

Tim SOC menangkap serangan ini dengan mengawasi modifikasi (*Event ID 5136 Directory Service Changes*) terhadap spesifik atribut `msDS-KeyCredentialLink`. Jika yang mengubahnya bukanlah layanan pembaruan sistem yang sah (seperti *Azure AD Connect* atau LAPS), bunyikan alarm kritis.

4.7 Active Directory Certificate Services (AD CS)

Kerentanan terbesar yang sering dilupakan oleh Arsitek Perusahaan di era modern adalah **AD CS (Active Directory Certificate Services)**, yang bertindak sebagai Otoritas Sertifikat (CA) internal. Kesalahan konfigurasi (*Misconfigurations*) pada templat (*Templates*) sertifikat internal ini menciptakan badai kategori serangan yang dinamai oleh peneliti (SpecterOps) sebagai **ESC1 hingga ESC14**.

Misalnya, **Eskalasi ESC1:** Jika sebuah templat Sertifikat Klien mengizinkan pemohon untuk memberikan *Subject Alternative Name (SAN)* mereka sendiri, dan templat tersebut diizinkan untuk digunakan dalam Autentikasi Klien (*Client Authentication*), bencana terjadi.

Seorang penyerang berlevel pengguna biasa (*Domain User*) dapat meminta penerbitan sertifikat dari AD CS dan mengisi kolom SAN dengan nama `DomainAdmin_Bob`. Sistem secara buta menerbitkan sertifikat tersebut. Penyerang lalu menggunakan sertifikat sah namun palsu ini untuk autentikasi Kerberos PKINIT, dan seketika mendapatkan tiket TGT sebagai *DomainAdmin_Bob*.

Proteksi dari penyalahgunaan AD CS bukanlah deteksi pasif, melainkan pengerasan (*Hardening*) dan Audit konfigurasi (Menggunakan alat sumber terbuka seperti **Certipy** atau **BloodHound 4.2+**).

4.8 Membangun Model Tiering AD (Tier 0, 1, 2)

Semua serangan ekskalasi hak istimewa (*Pass-the-Hash*, *Silver Ticket*, *DCSync*) memiliki satu akar masalah mendasar yang sama: **Kredensial berlevel tinggi (seperti Domain Admin) terekspos secara fisik/logis (tertinggal di RAM) pada komputer berlevel rendah (laptop staf atau server biasa).**

Untuk menghentikannya, Microsoft merekomendasikan rekayasa pembatasan akses yang disebut **Active Directory Tiering Model**.

- **Tier 0 (Identitas, DC, PKI):** Puncak piramida. Hanya mesin *Domain Controller*, *Azure AD Connect*, dan peladen PKI. **Administrator Tier 0 HANYA diizinkan *login* pada mesin Tier 0.**
- **Tier 1 (Peladen, Aplikasi, Database):** Peladen basis data, peladen web, dan *file share* perusahaan. Admin Tier 1 mengelola ini, tetapi TIDAK diizinkan masuk (*login*) ke mesin Tier 2.
- **Tier 2 (Workstation/Endpoint):** Ratusan/ribuan laptop karyawan dan meja layanan IT (*Helpdesk*).

Jika kebijakan *Tiering* ini dikunci menggunakan GPO (*Deny Log On Rights*), maka skenario *Pass-the-Hash* hancur berantakan. Jika seorang *Domain Admin* (Tier 0) mencoba membuka (*RDP*) ke laptop karyawan yang terinfeksi *malware* (Tier 2), Windows akan **Menolak** koneksi tersebut. Hash Admin Tier 0 tidak akan pernah mendarat di RAM mesin Tier 2. Peretas terperangkap selamanya di bawah (Tier 2).



BAGIAN V

Hybrid ITDR & Entra ID Cloud
(Menutup Celah)

BAB 5: HYBRID IDENTITY THREAT

5.1 Menjembatani On-Prem dan Cloud

Seiring perusahaan mengadopsi *Office 365 / Microsoft 365*, mereka tidak membuat kredensial awan (*Cloud*) yang sepenuhnya baru. Mereka ingin karyawan menggunakan sandi *Active Directory* (lokal/on-premise) untuk masuk (*login*) ke portal *Azure* (Entra ID).

Untuk mencapai ini, Microsoft menyediakan alat bernama **Azure AD Connect (Entra Connect)**. Peladen *AAD Connect* (yang berada di lingkungan lokal Anda) berstatus sebagai mesin berlabel **Tier 0**. Alat ini menyedot *Hash* kata sandi seluruh karyawan dari AD lokal, lalu mengirimkan *Hash* tersinkronisasi (*Password Hash Sync / PHS*) yang sudah dienkripsi ganda ke awan (*Cloud*).

Di masa lalu, penyerang yang berhasil masuk ke awan sering kesulitan turun ke jaringan *On-Premise*. Sebaliknya, penyerang (seperti insiden serangan *SolarWinds*) menyadari bahwa Azure AD Connect sangat berkuasa. Jika peretas (melalui *Golden Ticket* lokal) dapat meretas peladen *Azure AD Connect* lokal, mereka dapat menyuntikkan (*Inject*) perintah SAML rahasia untuk menciptakan **Golden SAML Attack**, meloncat mulus menyeberang dan mencuri seluruh infrastruktur aset *Cloud* (Sharepoint/OneDrive) tanpa halangan.

5.2 Pass-Through Authentication (PTA) Risks

Beberapa perusahaan besar (karena kebijakan regulasi atau privasi tingkat tinggi) menolak untuk menyinkronisasikan (*sync*) salinan kata sandi mereka ke *Cloud Microsoft* (PHS). Sebagai alternatif, mereka mengaktifkan **Pass-Through Authentication (PTA)**.

Dengan PTA, saat karyawan memasukkan *password* di portal `login.microsoftonline.com`, Microsoft akan mengirim *Password* (teks biasa/terenkripsi) kembali ke Agen PTA di *server On-Premise* perusahaan Anda secara *real-time*, membiarkan Active Directory lokal Anda yang memvalidasinya, lalu mengirim jawaban balik "Ya/Tidak" ke Microsoft.

> **Ancaman Vektor PTA:**
> Jika seorang peretas berhasil berkompromi dengan *Server Agent PTA On-Premise*, mereka tidak perlu bersusah payah membongkar DC. Mereka cukup menyadap (*sniff*) aliran data PTA yang melintasi mesin agen ini, karena teks autentikasi *Cloud* harus melewati gerbang tersebut untuk diverifikasi. Tim SOC (Tim Operasi Keamanan) **wajib** melarang akun Agen PTA dipasang di peladen biasa (Tier 1). Ia wajib berada di mesin isolasi mutlak (Tier 0).

5.3 Primary Refresh Token (PRT) Theft

Saat laptop Windows 10/11 karyawan bergabung dengan *Azure AD (Entra Joined)*, masuk (*login*) ke komputer pada pagi hari bukan sekadar autentikasi lokal. Proses itu berkomunikasi dengan awan (*Cloud*) dan mengunduh sebuah mahakarya kriptografik: **Primary Refresh Token (PRT)**.

PRT adalah *Super Cookie* rahasia (disimpan aman di dalam TPM/LSASS). Saat karyawan membuka *browser Edge* dan menavigasi ke kotak masuk (*Inbox*) *Outlook*, *browser* secara diam-diam meminjam PRT untuk mencetak *Session Cookie* otomatis (*Single Sign-On*). Karyawan masuk seketika tanpa ada permintaan sandi (*Password prompt*).

Peretas menggunakan alat *malware* termutakhir (seperti *Roadtools* atau *Mimikatz Cloud*) untuk mengekstrak (*Dump*) PRT atau *Session Cookie* sekunder dari mesin karyawan (*Cookie Theft*). Dengan mengekstrak PRT, peretas mencuri tiket awan. Mereka dapat membuka *browser* pribadi mereka di luar negeri, menyuntikkan (*Pass-the-PRT/Cookie*) token tersebut, dan langsung mendapatkan sesi (*bypass MFA* sepenuhnya).

SOC harus mengintegrasikan *Entra ID Risk Logs* dengan SIEM. Lonjakan IP asal yang janggal di tengah sesi *Cloud* yang sama, adalah tanda tangan mutlak dari PRT/Cookie *Theft*.

5.4 Identity Containment Playbooks (SOAR)

Bila deteksi ITDR (seperti DCSync, Golden Ticket, atau PRT Theft) berteriak dari SIEM, waktu adalah penentu nasib. Manusia (analis SOC) tidak cukup cepat bereaksi di pukul 2 dini hari (02:00). Mitigasi harus dijalankan otomatis oleh mesin **SOAR (Security Orchestration, Automation, & Response)**.

```
# Workflow Pseudo-SOAR: Aksi Containment Hibrida Ekstrem Trigger: SIEM mendeteksi Event 4662 (DCSync) oleh akun "Bob_Sysadmin" Node 1 (On-Premise): - API Call ke PowerShell AD Gateway: `Disable-ADAccount -Identity Bob_Sysadmin` - (Mencegah Bob melakukan login lateral lebih lanjut di lokal) Node 2 (Cloud Azure/Entra ID): - API Call (Graph API): `POST /users/Bob_Sysadmin/revokeSignInSessions` - (Menghancurkan dan menghapus semua Session Cookie PRT Bob di seluruh dunia) Node 3 (EDR / Endpoint): - API Call (CrowdStrike): `Isolate Host` pada IP sumber di mana Bob berada - (Mencekik fisik jaringan laptop peretas)
```

Dengan *Playbook* 3 arah ini, operasi peretas (di jaringan dan di awan) dipatahkan hanya dalam waktu kurang dari 5 detik setelah mereka membunyikan peringatan *DCSync* di SIEM.

5.5 Isolasi Otomatis Tier 0 Account

Satu peringatan operasional (*Operational Warning*) untuk implementasi SOAR: Pastikan Anda membangun mekanisme **"Human-in-the-Loop" (HitL)** atau Daftar Pengecualian (*Exclusion List*) yang kuat untuk akun-akun level sistem (seperti *Service Account Domain Controller* atau Agen *Azure AD Connect*).

Jika logika SIEM (KQL) Anda mengalami *False Positive* dan salah mengidentifikasi mesin DC1 sedang melakukan DCSync sebagai sebuah serangan (*padahal itu replikasi normal yang di-*update* oleh patch Windows baru), lalu SOAR berjalan, mesin otomatisasi Anda dapat menonaktifkan (*Disable*) akun *Domain Controller* Anda sendiri.

Mematikan akun DC sama dengan melakukan **Self-Inflicted Denial of Service (Serangan DoS Bunuh Diri)** pada seluruh operasional perusahaan. Perusahaan tidak bisa *login*, *Exchange Server* mati, dan jaringan runtuh, bukan karena peretas, melainkan karena robot pertahanan SOC Anda yang terlalu agresif.

GLOSARIUM ITDR (A-M)

TERMINOLOGI	DEFINISI & KONTEKS SERANGAN
AD CS	Active Directory Certificate Services. Fitur bawaan PKI (Public Key Infrastructure). Sering dikonfigurasi dengan buruk, memungkinkan eskalasi (ESC1-ESC14) menjadi *Domain Admin*.
AS-REQ / AS-REP	Tahap pertama Kerberos. Autentikasi dan permintaan awal kepada KDC (Key Distribution Center) untuk meminta TGT.
BloodHound	Alat sumber terbuka (*Open Source*) canggih yang memetakan, mengumpulkan (via *SharpHound*), dan memvisualisasikan seluruh hubungan hak istimewa (*Privilege Relationships*) di dalam direktori korporat.
DCSync	Teknik di mana penyerang berlagak (*impersonate*) sebagai *Domain Controller* melalui protokol replikasi, dan mengekstrak semua *hash* kata sandi dari direktori sentral.
Golden Ticket	Pemalsuan TGT tingkat dewa (*Ultimate TGT Forgery*). Dibuat secara luring (*offline*) oleh peretas menggunakan *hash* dari KRBTGT, memberikan akses universal ke segala sumber daya dan grup.
KRBTGT	Akun kunci (*Key Account*) sistem tersembunyi milik DC. *Password Hash*-nya digunakan untuk mengenkripsi serta memvalidasi keabsahan seluruh tiket Kerberos TGT di dalam satu Domain (Realm).

GLOSARIUM ITDR (N-Z)

TERMINOLOGI	DEFINISI & KONTEKS SERANGAN
NTLM Relay	Metode Man-in-the-Middle di LAN, di mana peretas menangkap permintaan *Hash NTLM* korban yang sedang transit dan meneruskannya (merelai) secara utuh ke peladen target untuk dieksekusi (Akses Jarak Jauh).
Pass-the-Hash (PtH)	Mengekstrak *Hash NTLM* yang tertinggal di RAM (biasanya menggunakan *Mimikatz*), lalu menggunakannya untuk autentikasi langsung, *bypass* (tanpa butuh) mengetahui sandi *plaintext*.
PRT (Primary Refresh Token)	Token kunci di ekosistem *Entra ID/Azure AD*. Mengelola *Single Sign-On* di peramban dan perangkat, setara nilainya dengan kredensial utuh jika berhasil diekstrak (dicuri) penyerang.
Silver Ticket	Pemalsuan tiket layanan tingkat tunggal (*TGS Forgery*). Dibuat menggunakan *hash* sandi curian milik spesifik *Service Account* (misalnya SQL Server). Memotong peran DC dalam validasi akses.
TGS (Ticket Granting Service)	Tiket tahap kedua. Bukti (Tiket Masuk) spesifik bahwa Anda memiliki izin untuk mengakses layanan dan peladen tertentu (seperti *File Share* atau *Database*).
TGT (Ticket Granting Ticket)	Tiket tahap pertama. Bukti (Gelang VIP) bahwa Anda berhasil melalui layar autentikasi utama (*Pre-Auth*). Diserahkan ke DC untuk meminta TGS.



```
Di dalam domain, identitas adalah segalanya.
Setiap proses, tiket, dan replikasi adalah jalur.
Amati aliran tersebut, dan pertahankan pusatnya.
```

The Infinite Defense

© 2026 Rizki Angga Pratama. All rights reserved.
SOC Training & Reference Material.